

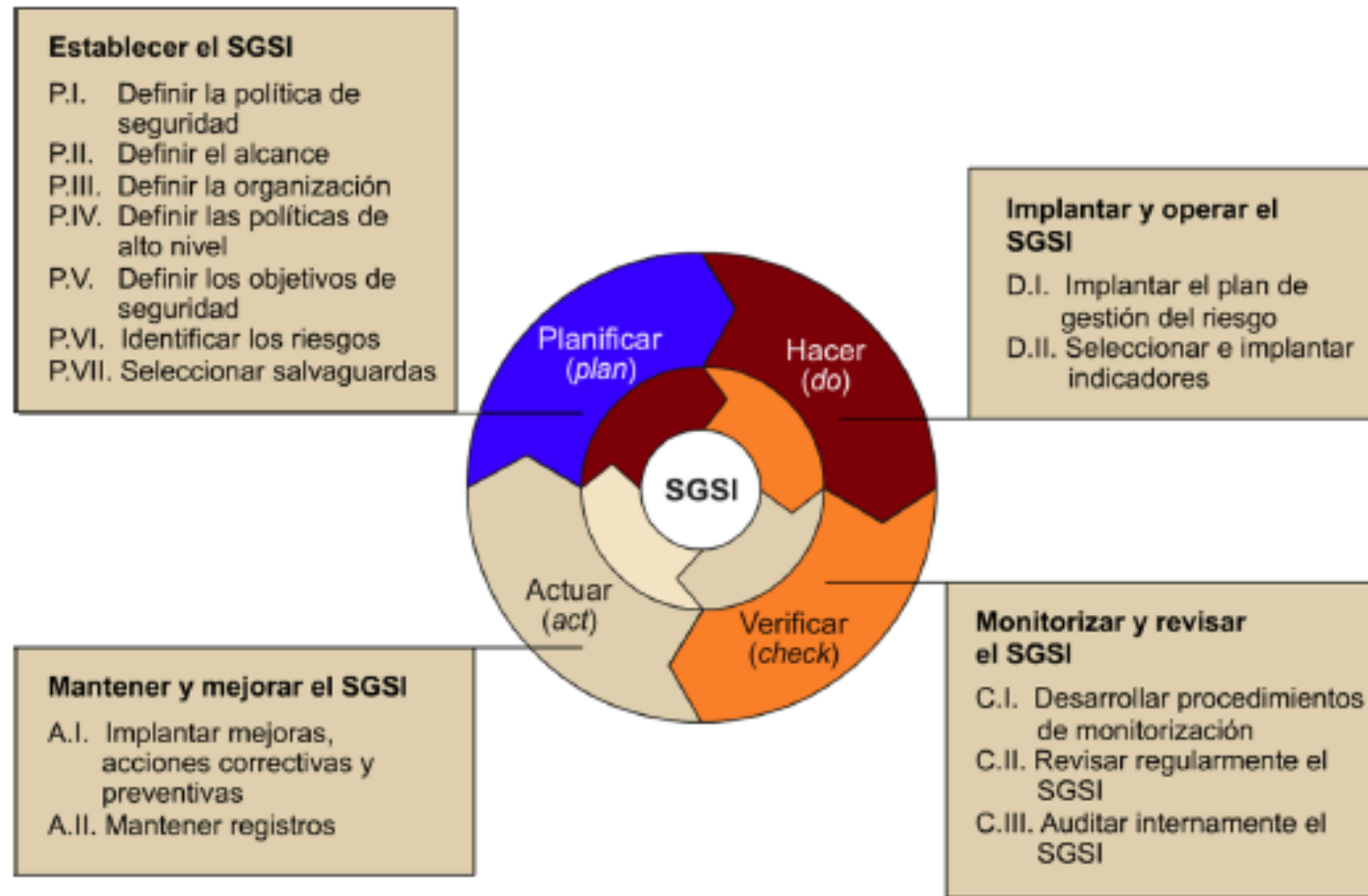
SISTEMA DE GESTION DE LA SEGURIDAD DE LA INFORMACIÓN

ELEMENTOS DE UN SGSI

- **Alcance del SGSI**
 - El alcance describe la extensión y los límites del SGSI, se trata de la selección de los elementos críticos que se deben proteger.
- **Política de Seguridad de la Información**
 - Declaración de la dirección y los objetivos de la organización en cuanto a la seguridad de la información.
 - Incluye las responsabilidades, la asignación de recursos y el compromiso de la alta dirección.
- **Organización de la Seguridad de la Información**
 - Establecimiento de una estructura organizativa para la seguridad de la información.
 - Asignación de roles y responsabilidades específicas.
- **Gestión de Activos**
 - Identificación y clasificación de los activos de información.
 - Implementación de medidas para proteger dichos activos.
- **Gestión del Riesgo**
 - Proceso de evaluación de riesgos de SI.
 - Proceso de tratamiento de riesgos de SI.
- **Monitoreo**
 - Definición de Indicadores sobre los controles.
 - Procedimientos de Auditorías internas y revisión de la conformidad.

Implantación de un Sistema de Gestión de Seguridad de la Información

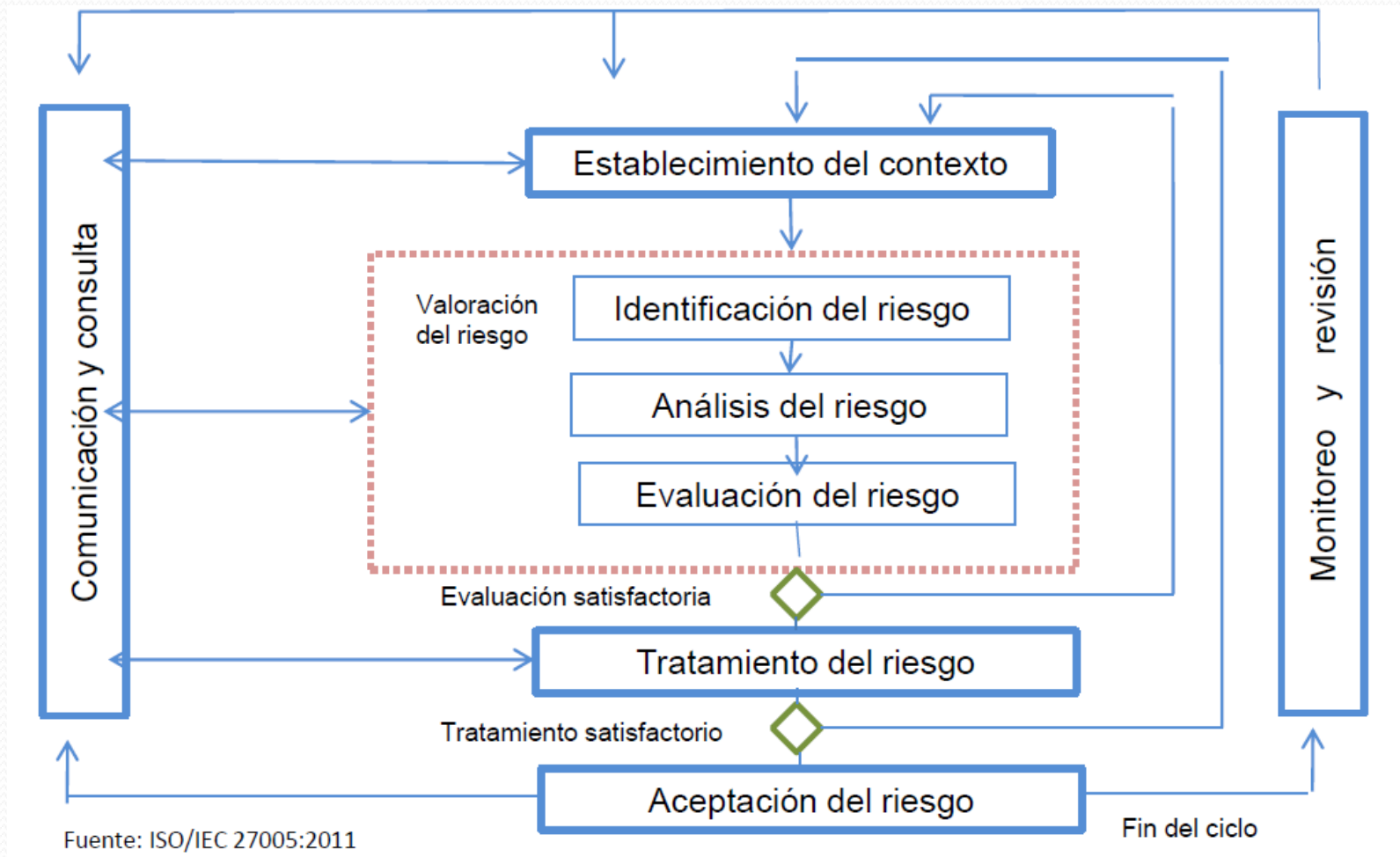
Ciclo de Deming aplicado a los sistemas de gestión de seguridad de la información



Procedimiento para la Creación de un SGSI

- **Iniciación del Proyecto**
 - Obtener el compromiso de la alta dirección.
 - Designar un equipo de gestión de la seguridad de la información.
- **Definición del Alcance**
 - Determinar el alcance del SGSI (qué procesos, unidades, y activos están incluidos).
 - Identificar las partes interesadas y sus necesidades.
- **Análisis de Riesgos**
 - Identificar y evaluar los riesgos relacionados con la seguridad de la información.
 - Realizar un análisis de impacto en el negocio.
- **Desarrollo de la Política de Seguridad de la Información**
 - Crear y aprobar la política de seguridad de la información.
 - Comunicar la política a toda la organización.
- **Implementación de Controles**
 - Seleccionar e implementar controles de seguridad adecuados basados en el análisis de riesgos.
 - Documentar los procedimientos y procesos de seguridad.
- **Formación y Concienciación**
 - Desarrollar e implementar programas de formación y concienciación para empleados y partes interesadas.
 - Asegurar que todos comprendan sus roles y responsabilidades en la seguridad de la información.
- **Monitoreo y Revisión**
 - Establecer procedimientos para monitorear y revisar la eficacia del SGSI.
 - Realizar auditorías internas y revisiones regulares.
- **Mejora Continua**
 - Revisar y mejorar continuamente el SGSI basado en los resultados de auditorías, incidentes y cambios en el entorno de la organización.

Proceso Gestión de Riesgos de SegInf



Identificación de Riesgos

Identificación de
activos

Clasificación de
activos

Identificación de
amenazas

Determinación de
vulnerabilidades

Evaluación de
controles
existentes

Análisis de Riesgos

Valoración de
Impacto

Valoración de
Probabilidad

Determinación
del Riesgo

Evaluación del Riesgo

Riesgo = Impacto x Probabilidad

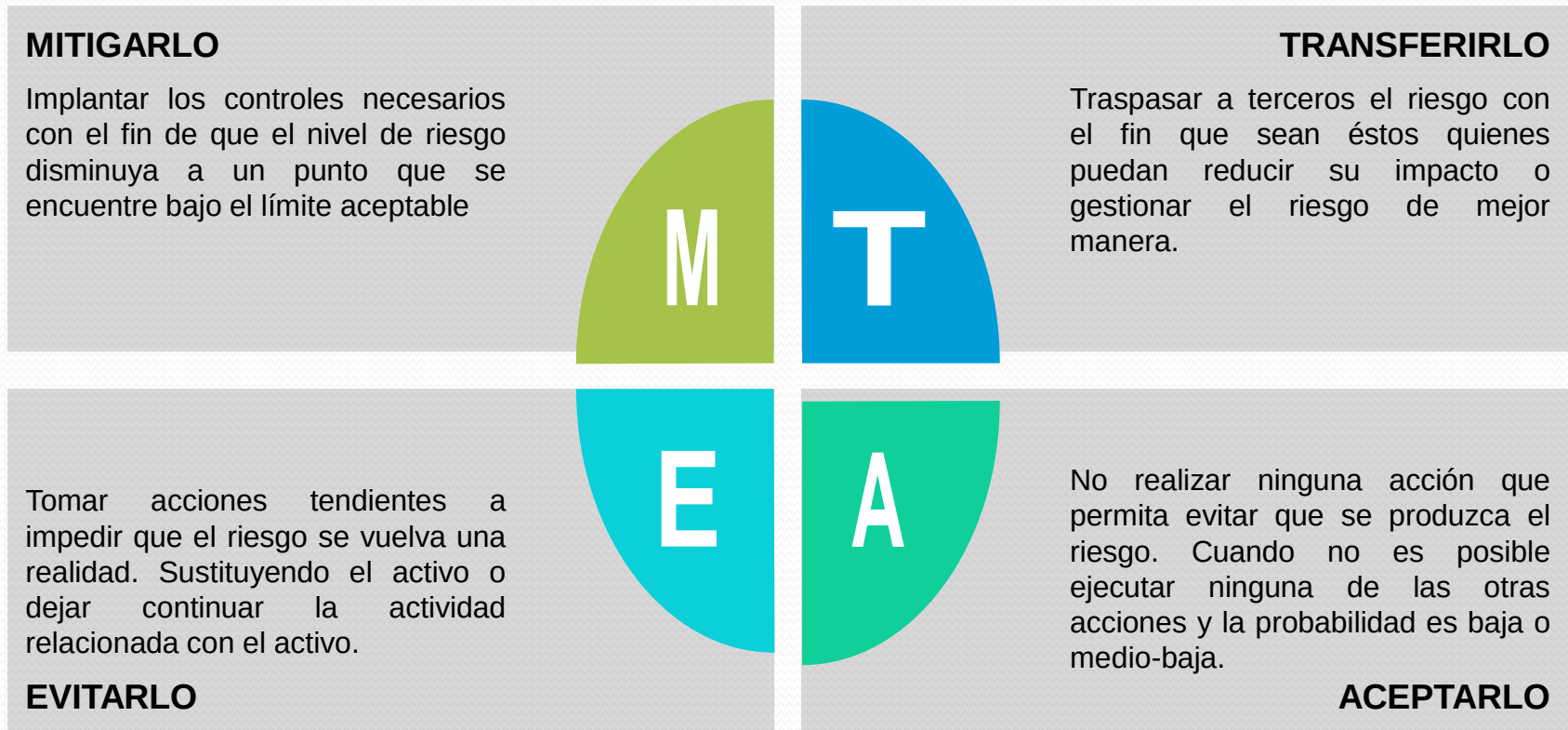
RIESGO		Frecuencia				
		MB	B	M	MA	A
Impacto	MA	A	MA	MA	MA	MA
	A	M	A	A	MA	MA
	M	B	M	M	A	A
	B	MB	B	B	M	M
	MB	MB	MB	B	B	B

Capacidad de riesgo – La cantidad objetiva de pérdida que una empresa puede tolerar sin poner en riesgo su existencia.

Difiere del apetito de riesgo, el cual es una decisión de la dirección sobre cuánto es deseable.

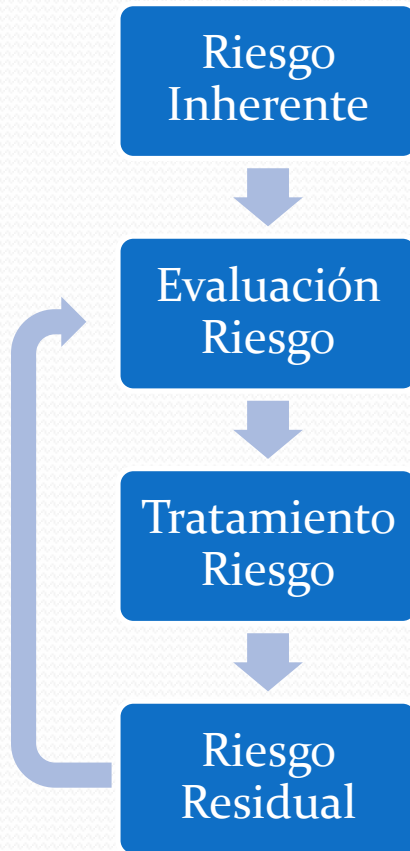
Tratamiento de Riesgos

Son tratados los riesgos que se encuentran por arriba del nivel aceptable, eligiendo entre una de las siguientes 4 opciones:



Apetito de riesgo – Cantidad y tipo de riesgo que una entidad desea aceptar en la consecución de su misión.

Ciclo del Riesgo



RIESGO INHERENTE: El Riesgo en ausencia de tratamiento

RIESGO RESIDUAL: Permanece después de haber ejecutado las respuestas a los riesgos

Controles de Seguridad

Según su
naturaleza

- Técnicos
- Organizativos

- Reducción de Probabilidad
- Reducción de Impacto
- Reducción de los 2 aspectos

Según el aspecto
que abordan

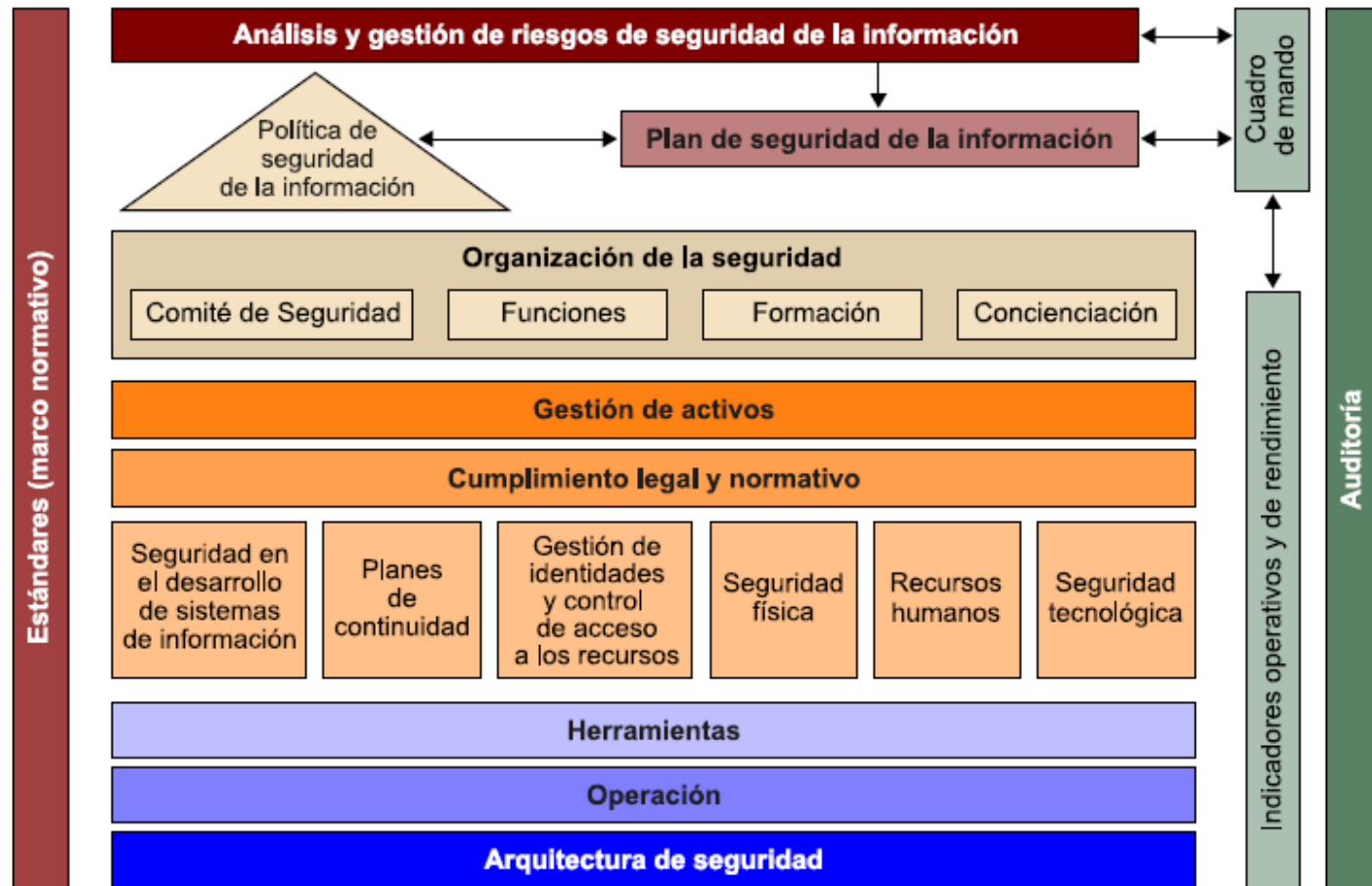
Según la
finalidad

- Preventivos
- de Detección
- Correctivos
- de Monitorización

- Tecnológico
- Operativo
- Reputacional
- Cumplimiento Legal

Riesgos
Mitigados

Interacción componentes del SGSI



El proceso de gestión de la seguridad de la información.